

DOCUMENTO DE AUDITORÍA: INFORME DE INYECCIÓN DE COMANDOS Y RESTRICCIÓN DE CÓDIGO FUENTE (OWASP TOP 10)

Fecha de Ejecución: 10 de Julio de 2026

Analista Responsable: Federico Fijtman (Técnico Superior en Programación / Analista GRC)

Herramienta Utilizada: Formulario Web DVWA (Security Level: Low) & Netcat Listener

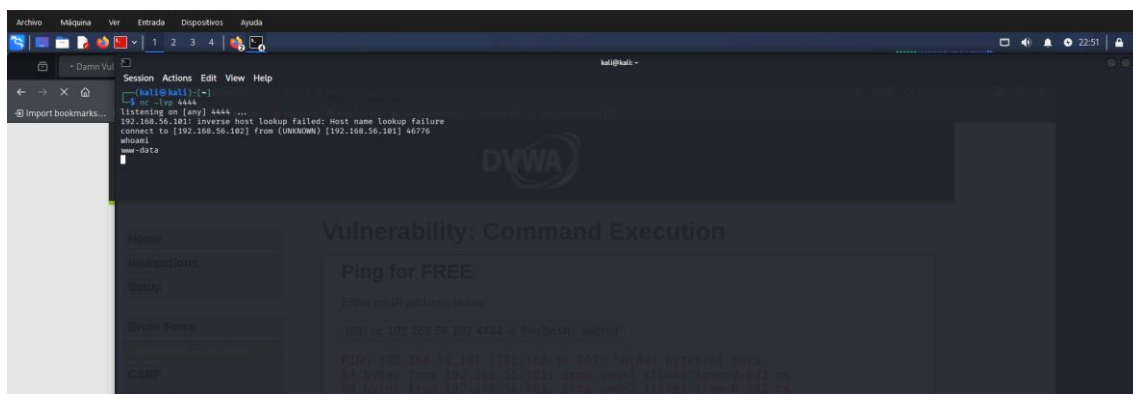
Objetivo Auditado (Target): Aplicación Web Corporativa - IP 192.168.56.101 (Puerto 80)

1. ALCANCE Y CONTEXTO DEL HALLAZGO

Durante la fase de análisis activo sobre el portal web del activo 192.168.56.101, se identificó un fallo de inyección de comandos de severidad Crítica, catalogado dentro del estándar internacional [OWASP Top 10](#) bajo la categoría A03:2021-Injection. La falla reside en la falta de sanitización y validación de las entradas provistas por el usuario en el formulario de diagnóstico de red.

2. PRUEBA DE CONCEPTO Y EXPLOTACIÓN (PoC)

- **Paso 2.1: Análisis de Código Fuente:** El análisis del backend de la aplicación reveló el uso de la función insegura `shell_exec()` encadenada por concatenación directa a la variable de entrada `$target` sin filtros de exclusión de caracteres especiales.
- **Paso 2.2: Inyección de Vectores:** Mediante el uso del operador separador punto y coma (;), se forzó al sistema operativo subyacente a procesar instrucciones secundarias ajenas al software web original, logrando extraer el inventario completo de cuentas locales del archivo `/etc/passwd`.
- **Paso 2.3: Conexión Reversa Persistente:** Se inyectó una cadena de ejecución conteniendo instrucciones de Netcat dirigidas al puerto 4444 de la máquina de control del analista (192.168.56.102). El servidor objetivo evadió los controles perimetrales entablando una consola remota interactiva bajo los privilegios del usuario de servicios `www-data`.



3. PLAN DE REMEDIACIÓN RECOMENDADO POR GRC

Se debe prohibir terminantemente el uso de funciones que invoquen intérpretes de comandos del sistema operativo (`shell_exec`, `exec`, `system`). La entrada del usuario debe ser validada mediante listas blancas estrictas utilizando expresiones regulares o, idealmente, reemplazando la ejecución de comandos por funciones nativas del lenguaje de programación (como las bibliotecas internas de red de PHP) para evitar el escape del entorno web.